Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 1.6 / COMPANION WORKBOOK

Configure the two-tier PKI

Offline root, issuing CA, pki.sbd.test publication & templates

Build a complete two-tier public key infrastructure: an offline standalone Root CA and an enterprise issuing CA, signed through a controlled ceremony, with trust data served from pki.sbd.test at the exact embedded URLs, template administration on its own seat, certificates for both domain controllers, and enrollment and revocation proven end to end.

MATERIALS EDITION 2.2 / COURSE 1.6

Updated 14 October 2026 · sbd-two-tier-pki

NAME _____ / DATE _____

Table of contents

Read each lesson alongside the interactive guide and the video. Use the record tables to write down what you actually observe — the workbook is your evidence, not the guide.

Before you start

01 Design the two-tier trust hierarchy

02 Configure the offline Root CA

03 Create the issuing CA request

04 Sign through the offline ceremony

05 Activate the issuing CA and distribute trust

06 Build the pki.sbd.test publication site

07 Publish the trust data at its advertised URLs

08 Separate template administration

09 Publish the first working templates

10 Validate enrollment, revocation, and recovery

Course review and sign-off

> **HOW TO USE IT** Each lesson page has the same shape: what you will learn, the build steps, the commands that verify them, and a record table. Fill the table from your own environment — never from the sample values.

© 2026 Secure By Design Team LLC.

Before you start

This course builds the whole PKI: a standalone offline Root CA, an enterprise subordinate/issuing CA, the pki.sbd.test publication site on SBD-PKI-MGMT01, template administration on its own seat, and certificates for both domain controllers. The root stays disconnected; approved removable media carries requests and public artifacts, and its clock is set from the approved reference at every session. Until course 1.8 builds AdminJumpBox01, work at each server's own console. Publication stays plain HTTP by design — clients must be able to fetch revocation data before they can validate any certificate.

Prerequisites

- ☐ Complete courses 1.1–1.5: both domain controllers healthy and replicating, DNS (course 1.2) with the pki.sbd.test alias reserved, the domain time hierarchy (course 1.3), course 1.4's DISA media set and baseline method, and course 1.5's OU structure, member-server policies and exception record; verify domain health and internal name resolution.
- ☐ Prepare separate Windows Server hosts: SBD-ROOTCA01, a disconnected workgroup machine in the offline vault, and two virtual machines with the hypervisor's time synchronization off, taking their time from the domain: SBD-SUBCA01 (10.0.30.20) joined to sbd.test, and SBD-PKI-MGMT01 (10.0.30.30) as a hardened member server, both joined straight into the Servers OU (course 1.8 moves them, with their administration, to a Tier 0 Servers OU).
- ☐ Approve the CA names, cryptography, validity periods, publication URLs, administration, backups, and removable-media procedure before installation; confirm the network's service-path register permits HTTP to pki.sbd.test (rule F18) and carries a row for certificate enrollment from the domain controllers to SBD-SUBCA01, which lesson 10 relies on.

What this course builds

- Design the CA hierarchy and its publication dependencies.
- Configure the offline root and sign an issuing CA request through controlled media transfer.
- Publish certificates and CRLs at the exact URLs issued certificates carry, from pki.sbd.test.
- Move template administration to a delegated seat, give both domain controllers their certificates, and prove autoenrollment and revocation end to end.

Systems in scope

RECORD	YOUR OBSERVATION
SBD-ROOTCA01 — name, address, OS build	
SBD-SUBCA01 — name, address, OS build	
SBD-PKI-MGMT01 — name, address, OS build	

© 2026 Secure By Design Team LLC.

LESSON 01 / ABOUT 25 MIN

Design the two-tier trust hierarchy

> **WHY THIS MATTERS** The root establishes trust. The subordinate, also called the issuing CA in this design, handles approved end-entity certificates. Keeping these roles separate protects the root from daily network exposure.

In this lesson you will

- Explain why the root stays offline while the issuing CA handles enrollment.
- Record the CA identities, cryptography, lifetimes, and CRL periods before installation, starting from this lab's example values.
- Plan AIA and CDP publication locations that clients can reach inside the air gap.

Follow the build

1. Draw the hierarchy: offline standalone root → enterprise issuing CA → approved server/client certificates. There is no network connection to the root.
2. Record final host and CA names, key provider, algorithm, key sizes, hashes, validity periods, renewal owners, and recovery arrangements. Start from this lab's example values in the next step and change any that your own policy requires: they are examples, not universal requirements.
3. Example values for this lab: the root CA uses an RSA 4096 key with SHA-256 and a 20-year certificate, and publishes a base CRL every 26 weeks with an overlap period and no delta CRL, refreshed at each offline ceremony. The issuing CA uses RSA 4096 (3072 at minimum) with SHA-256 and a 10-year certificate, a weekly base CRL, and a daily delta CRL. End-entity certificates last one to two years. NIST SP 800-57 Part 1 rates RSA 2048 at 112 bits of security, which it accepts for new signatures only through 2030, so a CA that will still be signing after 2030 uses at least 3072 bits (128 bits of security); the newest Windows Server release requires at least 2,048-bit RSA for TLS server authentication.
4. Know where each value is set. You choose the key, the hash, and the root's 20-year validity in the AD CS Configuration wizard. Each CA's CAPolicy.inf sets its CRL periods (CRLPeriod, CRLPeriodUnits, CRLDeltaPeriod, CRLDeltaPeriodUnits), which certutil -setreg can change later. The issuing CA's 10-year lifetime is set on the root (CA\ValidityPeriod and CA\ValidityPeriodUnits) before the signing ceremony, because a subordinate CA's lifetime comes from the CA that signs it.
5. Plan a stable internal publication name such as pki.sbd.test. The Authority Information Access (AIA) location supplies issuer certificates; the CRL Distribution Point (CDP) supplies certificate revocation lists.
6. Choose the publication host, paths, access rules, and refresh schedule before issuing certificates. Clients inside this air-gapped network must reach those locations without relying on the public internet.

Check your result

```
# Run on the future issuing CA, not the offline root.
Get-CimInstance Win32_ComputerSystem | Select-Object Name, Domain, PartOfDomain
Resolve-DnsName SBD-DC01.sbd.test
Resolve-DnsName SBD-DC02.sbd.test
```

> **WHAT SUCCESS LOOKS LIKE** The written plan separates trust, issuance, publication, and administration. It identifies who renews CRLs before they expire, and every key size, hash, lifetime, and CRL period has a recorded value and the setting that applies it.

Your record

Evidence to keep: Keep the approved hierarchy, the cryptography and lifetime table with the setting that applies each value, and a worksheet mapping every certificate/CRL URL to its actual publisher and file.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Which role issues routine server certificates in this design?

REMEMBER Trust, issuance, publication, and administration are separated in writing. Cryptography, names, lifetimes, and CRL periods are approved before installation, starting from this lab's example values. CRL renewal has a named owner and a date.

Microsoft · PKI design considerations

Microsoft · CAPolicy.inf syntax

NIST · SP 800-57 Part 1 Rev. 5, Recommendation for key management

LESSON 02 / ABOUT 30 MIN

Configure the offline Root CA

WHY THIS MATTERS Treat root installation as a controlled event. Its private key is the highest-value secret in the hierarchy, and its configuration shapes the subordinate certificate it will sign.

In this lesson you will

- Verify the disconnected workgroup host before installing the role.
- Install a standalone root CA with the approved CAPolicy.inf and settings.
- Configure publication URLs and the CRL schedule before signing anything.

Follow the build

1. Verify SBD-ROOTCA01 is in a workgroup with no active network path. Prepare approved installation media, protected administration, and backup storage, and set its clock from the approved reference that course 1.3 names, recording both readings: no network will ever correct this clock.
2. Place the reviewed CAPolicy.inf in %SystemRoot% before configuration. Tailor it to the root role: in this lab it sets CRLPeriod=Weeks and CRLPeriodUnits=26, and CRLDeltaPeriodUnits=0 so the root publishes no delta CRL. A self-signed root's own CDP/AIA choices differ from the extensions the root places into issued subordinate certificates.
3. Install the Certification Authority role with management tools. In the AD CS Configuration wizard choose Standalone CA, Root CA, and a new private key, then apply the approved provider, cryptography (RSA 4096 with SHA-256 in this lab), CA name, validity (20 years), database, and log settings.
4. Before signing anything, configure the root's issued-certificate AIA/CDP settings, the subordinate validity policy (CA\ValidityPeriod Years and CA\ValidityPeriodUnits 10 in this lab), and the base-CRL schedule (26 weeks with an overlap period, and no delta CRL). Hold requests for explicit approval. Produce and inspect a current root CRL, then capture a protected CA backup.

Check your result

```
# Inspect locally on SBD-ROOTCA01 during the approved root session.
Get-CimInstance Win32_ComputerSystem | Select-Object Name, Domain, PartOfDomain
Get-Date -Format 'yyyy-MM-dd HH:mm:ss.fff K'   # read against the approved reference; log
both readings
Get-Service CertSvc
certutil -getreg CA\CRLPublicationURLs
certutil -getreg CA\CACertPublicationURLs
certutil -getreg CA\ValidityPeriodUnits
certutil -getreg CA\CRLPeriodUnits
```

WHAT SUCCESS LOOKS LIKE The host remains disconnected, its clock matches the approved reference, the CA is standalone/root, requests require approval, and the planned subordinate URLs and 10-year subordinate validity are configured before signing.

Your record

Evidence to keep: Record the root certificate identity, policy file, publication settings, CRL dates, backup location, the clock check, and operator sign-off. Protect backups containing private keys.

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

When must the root's issued-certificate publication URLs be configured?

REMEMBER The root host stays disconnected, with controlled media, administration, and time. CAPolicy.inf is in place before the role is configured. Publication URLs, validity policy, the CRL schedule, and a protected backup exist before any signing.

Microsoft · CAPolicy.inf syntax

Microsoft · Install the offline root

Microsoft · Perform the offline root signing ceremony

LESSON 03 / ABOUT 25 MIN

Create the issuing CA request

> **WHY THIS MATTERS** Prepare the online issuing server, but keep issuance paused until its CA certificate has been signed and installed. The request carries the public key; the private key stays protected on the issuing system or its approved key provider.

In this lesson you will

- Prepare the domain-joined issuing host with its final identity.
- Generate the subordinate CA request without exposing the private key.
- Verify and hash the request before it travels to the root.

Follow the build

1. Confirm SBD-SUBCA01 has its final hostname, domain membership, static address (10.0.30.20), internal DNS, and its time from the domain hierarchy, with the hypervisor's time synchronization off. Use a dedicated host and the privileges approved for enterprise CA configuration.
2. Prepare its role-specific CAPolicy.inf (in this lab: CRLPeriod=Weeks, CRLPeriodUnits=1, CRLDeltaPeriod=Days, CRLDeltaPeriodUnits=1, and LoadDefaultTemplates=0) and protected request directory. Decide which templates may later be published instead of enabling a broad default enrollment set.
3. Install the CA role and management tools. In the AD CS Configuration wizard choose Enterprise CA, Subordinate CA, and the approved new-key/provider settings (RSA 4096 with SHA-256 in this lab). Enter the planned CA identity and storage locations.
4. Choose Save a certificate request to file. Inspect the resulting request's subject, public key, and CA constraints; record its SHA-256 hash before handing it to the media custodian.

Check your result

```
w32tm /query /source   # a domain controller, never Local CMOS Clock or a hypervisor
provider
# Use the actual request path chosen in the wizard.
certutil -dump C:\CAConfig\IssuingCA.req
Get-FileHash -Algorithm SHA256 C:\CAConfig\IssuingCA.req
```

> **WHAT SUCCESS LOOKS LIKE** The request matches the approved issuing identity and key profile. The CA is waiting for its signed certificate; do not troubleshoot that expected state by installing another CA.

Your record

Evidence to keep: Retain the request, its reviewed fields and hash, and the request-transfer record. Do not place private keys in the transfer package.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	

RECORD	YOUR OBSERVATION
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What moves to the offline root for signing?

> **REMEMBER** The issuing host has its final name, addressing, DNS, and time before the role install. The request file carries the public key only. The request's fields and hash are reviewed and recorded before transfer.

Microsoft · CAPolicy.inf syntax

Microsoft · Deploy the issuing CA role

LESSON 04 / ABOUT 30 MIN

Sign through the offline ceremony

> **WHY THIS MATTERS** A signing ceremony connects an approved request to an approved CA identity. A matching filename alone is not proof that the root should trust the request.

In this lesson you will

- Verify the root's clock and the request's integrity before submission.
- Issue the subordinate certificate under the approved validity policy.
- Export and verify the public artifacts, then return the root to a secured state.

Follow the build

1. Use approved removable media and custody procedures to bring the request to the root. Before signing, read the root's clock against the approved reference and correct it by the measured difference if it is past the threshold: the certificate and CRL dates it signs come from that clock. Recalculate the request's hash, compare it with the independently recorded value, and inspect the request before submission.
2. Verify the root's issued-certificate validity policy and publication extensions. In Certification Authority, submit the request, review its pending entry, and issue it only after the required approval.
3. Export the subordinate certificate, root certificate, and current root CRL. Check identities, constraints, validity, signatures, URLs, and revocation data against the approved hierarchy. Record file hashes and the request ID.
4. Transfer only the approved public artifacts back to the connected environment. Match published filenames to the URLs embedded in certificates, retain the ceremony record and protected backup, then shut down and secure the root.

Check your result

```
# On SBD-ROOTCA01, first: read this against the approved reference and log both readings
Get-Date -Format 'yyyy-MM-dd HH:mm:ss.fff K'
# Inspect public artifacts; use your actual approved paths.
certutil -dump C:\CAConfig\IssuingCA.cer
certutil -dump C:\CAConfig\RootCA.crl
Get-FileHash -Algorithm SHA256 C:\CAConfig\IssuingCA.cer, C:\CAConfig\RootCA.cer, C:\
CAConfig\RootCA.crl
```

> **WHAT SUCCESS LOOKS LIKE** The root's clock matched the approved reference, and artifact identities, signatures, validity, and custody checks pass. The root remains offline; a field dump alone is not end-to-end trust validation.

Your record

Evidence to keep: Keep the clock check, approval, request ID, artifact hashes, verified certificate/CRL properties, media custody, and root shutdown evidence together.

RECORD	YOUR OBSERVATION
Host(s) and time collected	

RECORD	YOUR OBSERVATION
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Which transfer preserves the root boundary?

REMEMBER Integrity is verified before submission, and issuance follows explicit approval. Artifact identities, validity, and URLs are checked against the plan. The ceremony record, hashes, and root shutdown are all evidence.

Microsoft · Perform the offline root signing ceremony

LESSON 05 / ABOUT 25 MIN

Activate the issuing CA and distribute trust

> **WHY THIS MATTERS** A signed certificate is not yet a working CA. Install it, start Certificate Services, set the AIA and CDP locations every issued certificate will carry, and distribute the approved root through managed domain policy.

In this lesson you will

- Install the signed certificate and start Certificate Services.
- Configure the AIA and CDP URLs before any certificate is issued.
- Distribute root trust through managed domain policy.

Follow the build

1. Verify the returned artifacts and add the approved root certificate and the current root CRL to the issuing server's local stores: the CA checks its own chain when it starts, before pki.sbd.test serves those files. Complete CA certificate installation through Certification Authority and start Certificate Services.
2. Configure the issuing CA's AIA and CDP settings before issuing any certificate, pointing them at the planned pki.sbd.test locations. Every certificate the CA signs carries these URLs, so they are fixed now and served exactly as written in lessons 6 and 7.
3. Distribute the approved root trust through the managed domain policy and arrange the required intermediate/directory publication with delegated administrators.
4. Hold off on certificate templates: lessons 8 and 9 give template administration its own seat and publish only the templates the plan needs.

Check your result

```
# Before installing the signed certificate: the ceremony's root certificate and CRL, into
the local stores
certutil -addstore -f Root C:\CAConfig\RootCA.cer
certutil -addstore -f Root C:\CAConfig\RootCA.crl
# Inspect the issuing CA after installation and publication.
Get-Service CertSvc
certutil -getreg CA\CRLPublicationURLs
certutil -getreg CA\CACertPublicationURLs
certutil -store Root
certutil -store CA
```

> **WHAT SUCCESS LOOKS LIKE** Certificate Services is running, the AIA and CDP settings carry the planned pki.sbd.test URLs, and the approved root reaches domain clients through policy.

Your record

Evidence to keep: Keep the CA installation record, the AIA and CDP settings, and the trust-distribution policy.

RECORD	YOUR OBSERVATION
Host(s) and time collected	

RECORD	YOUR OBSERVATION
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why are the AIA and CDP URLs set before the issuing CA signs its first certificate?

> **REMEMBER** The issuing CA is running with its signed certificate. AIA and CDP URLs are set before the first certificate is issued. Root trust distributes through managed domain policy.

Microsoft · Publish trust data and validate clients

Microsoft · Certutil reference

LESSON 06 / ABOUT 30 MIN

Build the pki.sbd.test publication site

> **WHY THIS MATTERS** Every certificate the issuing CA has signed carries the pki.sbd.test URLs inside it. This lesson gives those URLs a real home: a small web site on SBD-PKI-MGMT01 serving certificates and revocation lists to the whole network.

In this lesson you will

- Stand up the HTTP publication site on SBD-PKI-MGMT01.
- Confirm the DNS alias from course 1.2 points at the publication host.
- Explain why CDP and AIA publication uses HTTP, not HTTPS.

Follow the build

1. On SBD-PKI-MGMT01, install the Web Server role and create a site (or virtual directory) whose folder will hold the published certificates and revocation lists. Serve .cer, .crt, and .crl files, and allow double escaping in that site's request filtering only, because delta CRL file names carry a + that IIS otherwise refuses; nothing else belongs in this directory.
2. From SBD-DC01 in VLAN 10, outside VLAN 30, confirm the pki.sbd.test alias from course 1.2 resolves to 10.0.30.30 and that rule F18 in the service-path register permits HTTP to the site.
3. Leave the site on plain HTTP. Revocation checking has to work before any certificate can be trusted — putting the CRL behind HTTPS creates a loop where validating the site needs the very file it serves.
4. Restrict who can write to the publication folder: the CA's publishing process and the PKI administrators, nobody else. Clients read; they never write.

Check your result

```
# On SBD-DC01 (VLAN 10): the name and the path from outside VLAN 30
Resolve-DnsName pki.sbd.test
Test-NetConnection pki.sbd.test -Port 80
# On SBD-PKI-MGMT01: the site, and double escaping allowed there for delta CRL names
Get-Website | Select-Object Name, State, PhysicalPath
Get-WebConfigurationProperty -PSPath 'IIS:\Sites\<PKI site>' -Filter
system.webServer/security/requestFiltering -Name allowDoubleEscaping
```

> **WHAT SUCCESS LOOKS LIKE** pki.sbd.test resolves to the publication host from outside VLAN 30, the site answers on port 80 with double escaping allowed only there, and the publication folder's permissions separate writers from readers.

Your record

Evidence to keep: Record the site configuration, folder permissions, the DNS resolution output from SBD-DC01, and rule F18, the register row that permits the path.

RECORD	YOUR OBSERVATION
Host(s) and time collected	

RECORD	YOUR OBSERVATION
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why does the publication site stay on plain HTTP?

> **REMEMBER** pki.sbd.test now answers from SBD-PKI-MGMT01 over HTTP. Only public artifacts live in the folder; only PKI processes write to it. The transport is HTTP on purpose — revocation precedes trust.

Microsoft · PKI design considerations

Microsoft · Publish trust data and validate clients

Microsoft · Certutil reference

LESSON 07 / ABOUT 25 MIN

Publish the trust data at its advertised URLs

WHY THIS MATTERS A publication site is only correct when the filenames it serves match the URLs the certificates already carry. Copy the current certificates and CRLs into place, wire the issuing CA to keep them fresh, and prove retrieval from a client that has never cached anything.

In this lesson you will

- Publish the root and issuing certificates and current CRLs at the exact embedded URLs.
- Configure the issuing CA to refresh its published files automatically.
- Prove live retrieval and chain building from outside VLAN 30.

Follow the build

1. Compare the issuing CA's configured AIA and CDP URLs against the publication folder's layout. Every embedded URL must map to a real file path on the site — the filenames are not yours to improve.
2. Copy the current root certificate, root CRL, issuing certificate, and issuing CRL into the folder. The root's files still arrive by approved media; the issuing CA's can be written directly by its publishing process.
3. Configure the issuing CA's CRL publication to write into the site's folder on its schedule, so each new CRL replaces the old file at the same name before it expires.
4. From SBD-DC01, outside VLAN 30, clear the URL cache and verify the issuing CA's certificate with live retrieval: the chain must build to the root and the root's CRL must come from the live site, not a cache. Fetch the issuing CA's own base and delta CRLs at their URLs too; the certificates it issues from lesson 9 on point clients at them.

Check your result

```
# On SBD-DC01 (VLAN 10), with nothing cached; IssuingCA.cer is the ceremony's public
certificate
certutil -urlcache * delete
certutil -verify -urlfetch C:\Evidence\pki\IssuingCA.cer
'<issuing CA CRL name>.crl', '<issuing CA CRL name>+.crl' | ForEach-Object { (Invoke-
WebRequest "http://pki.sbd.test/$_" -UseBasicParsing).StatusCode }   # 200 for the base
and the delta CRL
# On SBD-PKI-MGMT01: what the site serves, with timestamps
Get-ChildItem C:\inetpub\pkiroot | Select-Object Name, LastWriteTime
```

WHAT SUCCESS LOOKS LIKE Every AIA and CDP URL the issuing CA's certificate carries returns the current file, urlfetch verification passes from SBD-DC01 outside VLAN 30, the issuing CA's base and delta CRLs answer at their URLs, and the CRL refresh lands at the same filename automatically.

Your record

Evidence to keep: Keep the URL-to-file mapping table, the folder listing with timestamps, and the urlfetch and CRL retrieval output from SBD-DC01.

RECORD	YOUR OBSERVATION
Host(s) and time collected	

RECORD	YOUR OBSERVATION
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why can't the published filenames be renamed to something tidier?

> **REMEMBER** Published filenames mirror the embedded URLs exactly. The issuing CA refreshes its files on schedule; the root's arrive by media. A cache-cleared check from outside VLAN 30 proves the chain and live revocation.

Microsoft · PKI design considerations

Microsoft · Publish trust data and validate clients

Microsoft · Certutil reference

LESSON 08 / ABOUT 25 MIN

Separate template administration

WHY THIS MATTERS Certificate templates are directory objects, and whoever edits them decides what the PKI will sign. Give that power its own seat — SBD-PKI-MGMT01 — with named administrators, instead of leaving it wherever a CA console happens to be open.

In this lesson you will

- Establish SBD-PKI-MGMT01 as the only administration seat for templates.
- Delegate template permissions to a named PKI administrators group.
- Record the template change process before any template changes.

Follow the build

1. Install the certificate management tools on SBD-PKI-MGMT01 and confirm the Certificate Templates console can read the directory's template store from there.
2. Create the SBD PKI Admins group in the directory, place it in the Admin OU from course 1.5, and delegate the template permissions to that group — membership is the record of who may change what the CA signs.
3. Remove day-to-day template editing from everywhere else: the issuing CA's console stays for CA operations, not template design, and no Domain Admins or Enterprise Admins account edits templates as routine work.
4. Write the change process: a template change names its requester, its reviewer, the versioning action (edit, duplicate, or supersede), and lands in the evidence record like any other configuration change.

Check your result

```
Get-ADGroup 'SBD PKI Admins' -Properties Members | Select-Object Name, Members
certutil -template | Select-String 'TemplatePropCommonName' | Select-Object -First 10
```

WHAT SUCCESS LOOKS LIKE The templates console works from SBD-PKI-MGMT01, the PKI administrators group holds the delegated permissions, and the written change process names requester, reviewer, and versioning action.

Your record

Evidence to keep: Keep the delegation record, the group membership listing, and the signed-off template change process.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

Why do certificate templates deserve their own administration seat?

> **REMEMBER** SBD-PKI-MGMT01 is the template administration seat. A named group in the Admin OU holds the delegated power. Template changes have a written process before they have edits.

Microsoft · PKI design considerations

Microsoft · Manage certificate templates

LESSON 09 / ABOUT 30 MIN

Publish the first working templates

> **WHY THIS MATTERS** The default template set is a menu, not a deployment. Duplicate the three templates this network actually needs — domain controller, computer and server authentication — set their cryptography deliberately, and publish only those.

In this lesson you will

- Duplicate and configure the domain controller, computer and web server templates against the approved plan.
- Set key sizes and validity that meet the Windows Server minimums.
- Publish only the needed templates, with autoenrollment limited to the domain controllers and a pilot group.

Follow the build

1. From the administration seat, duplicate Kerberos Authentication, the template Microsoft designates for domain controllers, as SBD Domain Controller Authentication: subject name format None with the DNS name in the alternative name, a key storage provider with RSA keys of at least 2,048 bits and SHA-256, a validity within lesson 1's one-to-two-year example, and the Domain Controller, Domain Controller Authentication and Kerberos Authentication templates on its Superseded Templates tab. Confirm Domain Controllers and Enterprise Domain Controllers hold Read, Enroll and Autoenroll: this is the PKI server certificate the STIG expects on every domain controller, course 1.4's POA&M candidate.
2. Duplicate the Computer template as SBD Computer Authentication. Set the approved key provider, a key size of at least 2,048 bits, a validity period within the same example, subject built from directory information, and autoenrollment permission for a pilot computer group only — SBD-PKI-MGMT01 for now, until the fleet arrives in course 1.13.
3. Duplicate the Web Server template as SBD Server Authentication for the TLS services later courses build — the collector (course 1.10), SBD-SPLUNK01 (1.12), SBD-WSUS01 (1.14) and the business services (1.18): the subject supplied in the request, Enroll for the server administrators (a Linux host's request is made on the host and submitted from their seat) and for an SBD TLS Servers computer group (a Windows server requesting into its own computer store is checked against its computer account, so each later course adds its server to that group first), no autoenrollment, and exportable keys only if the recovery plan explicitly says so.
4. Record each template's version, settings, and justification through the lesson 8 change process before publishing.
5. Publish exactly these three templates on the issuing CA and remove any default template the plan does not call for — an unpublished template cannot be mis-enrolled.

Check your result

```
# On SBD-PKI-MGMT01: the templates the CA publishes (use your CA's host\name configuration
string)
certutil -CATemplates -config 'SBD-SUBCA01\SBD Issuing CA'
# Each SBD template's minimum key size and subject-name flags, read from the directory
Get-ADObject -SearchBase 'CN=Certificate Templates,CN=Public Key
Services,CN=Services,CN=Configuration,DC=sbd,DC=test' -Filter "Name -like 'SBD*'" -
```

```
Properties displayName, msPKI-Minimal-Key-Size, msPKI-Certificate-Name-Flag | Select-
Object Name, displayName, msPKI-Minimal-Key-Size, msPKI-Certificate-Name-Flag
```

WHAT SUCCESS LOOKS LIKE The CA publishes exactly the three planned templates, each shows the approved key size and permissions, and each carries a completed change record.

Your record

Evidence to keep: Keep each template's configuration export, its change record, and the CA's published-template listing.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why duplicate the built-in templates instead of editing them?

REMEMBER Three named templates exist, configured on purpose, nothing else published. Key sizes meet the platform's 2,048-bit floor; autoenrollment reaches only the domain controllers and the pilot group. Every template carries its change record.

Microsoft · Manage certificate templates

Microsoft · Configure certificate autoenrollment

Microsoft · What's new in Windows Server 2025

Microsoft · On-premises key trust deployment guide (domain controller certificates)

LESSON 10 / ABOUT 35 MIN

Validate enrollment, revocation, and recovery

WHY THIS MATTERS Finish the way relying systems see it: both domain controllers and a pilot machine enroll on their own, validate against the live publication site, and reject a certificate you revoke — then the closing scans record what this course changed and close course 1.4's domain controller certificate finding.

In this lesson you will

- Prove hands-free autoenrollment of the domain controller and pilot certificates through the published templates.
- Verify chain building and live revocation retrieval from pki.sbd.test, and prove revocation works.
- Schedule the renewals that keep the PKI alive, run the closing scans, close the domain controller certificate finding, and file the evidence.

Follow the build

1. Turn on autoenrollment: create SBD Certificate Autoenrollment, a GPO that enables Certificate Services Client - Auto-Enrollment with renewal and template updates, and link it at the domain root, so each member enrolls only for the templates whose permissions name it. The controllers' requests reach SBD-SUBCA01 over RPC across the core from VLAN 10, so confirm the register's enrollment row first. Refresh policy: both controllers receive SBD Domain Controller Authentication certificates and the pilot, SBD-PKI-MGMT01, an SBD Computer Authentication certificate, without a human touching a request.
2. On SBD-DC01, outside VLAN 30, export its new certificate and the pilot's, clear the URL cache, and run the full verification on each: the chain must reach the approved root and every AIA and CDP URL must answer from pki.sbd.test with current CRL dates — cached success is not evidence of publication.
3. Enroll a disposable test certificate, revoke only that one, publish an updated issuing CRL, and verify on SBD-DC01, with the cache cleared again, that a fresh evaluation detects the revocation. Diagnose retrieval or stale-publication problems rather than turning off revocation checks.
4. Record owners and reminders for root and issuing CRL publication, certificate renewal, backup, and an isolated recovery rehearsal. Schedule offline root ceremonies early enough to transfer and publish replacement CRLs before expiry, and start each one by setting the root's clock against the approved reference.
5. Take the first SCAP baselines of SBD-SUBCA01 and SBD-PKI-MGMT01 the course 1.4 way: SCC and the Windows Server benchmark from the course 1.4 media set, checked against its hashes, at the same versions and profile, run locally, with each session hashed and carried to C:\Evidence\pki\<host name> on SBD-DC01, where its hashes must match again, as SBD-DC02's did in course 1.4. List the IIS STIGs the publication site now falls under with an owner and a review date, then rescan both controllers the same way, because their certificates, root trust and autoenrollment policy are this course's change.
6. Close what this course fixed: in copies of the course 1.5 checklists in C:\Evidence\pki\checklists on SBD-DC01, answer the rule that every domain controller has a PKI server certificate Not A Finding, with each controller's certificate as the observation, and record course 1.4's POA&M candidate as closed. The companion rule, that those certificates come from the DoD PKI or an approved External Certificate Authority, stays open: record it in C:\Evidence\exception-record.csv if it is not there yet, because this lab's own hierarchy stands in for DoD's. Back up the new GPOs and export their links, file the enrollment, urlfetch, revocation, template and owner records with the scans, and seal C:\Evidence\pki.

© 2026 Secure By Design Team LLC.

Check your result

```
# On SBD-DC01, SBD-DC02 and the pilot, SBD-PKI-MGMT01, once SBD Certificate Autoenrollment
is linked at the domain root
gpupdate /force
certutil -pulse
Get-ChildItem Cert:\LocalMachine\My | Select-Object @{n='Template';e={ $x = $_.Extensions
| Where-Object { $_.Oid.Value -eq '1.3.6.1.4.1.311.21.7' }; if ($x)
{ $x.Format($false) } }}, DnsNameList, NotAfter, Thumbprint
# On SBD-DC01 (outside VLAN 30): export its certificate, then verify it and the pilot's
with nothing cached
New-Item -ItemType Directory C:\Evidence\pki -Force | Out-Null
$dc = Get-ChildItem Cert:\LocalMachine\My | Where-Object
{ $_.EnhancedKeyUsageList.ObjectId -contains '1.3.6.1.5.2.3.5' } | Select-Object -First 1
# KDC Authentication
Export-Certificate -Cert $dc -FilePath C:\Evidence\pki\SBD-DC01-dc.cer
certutil -urlcache * delete
certutil -verify -urlfetch C:\Evidence\pki\SBD-DC01-dc.cer
certutil -verify -urlfetch C:\Evidence\pki\pilot.cer   # the pilot's certificate, exported
on SBD-PKI-MGMT01 with Export-Certificate
# On SBD-SUBCA01: revoke only the disposable test certificate, then publish a new CRL
certutil -revoke '<test certificate serial number>' 5   # 5 = cessation of operation
certutil -crl
# Back on SBD-DC01: the test certificate must now fail as revoked
certutil -urlcache * delete
certutil -verify -urlfetch C:\Evidence\pki\test.cer
# After the scans (each carried to C:\Evidence\pki\<host name> on SBD-DC01) and the
checklist updates: back up the new GPOs, then seal the evidence
New-Item -ItemType Directory C:\Evidence\pki\gpo-backup -Force | Out-Null
Backup-GPO -Name 'SBD Certificate Autoenrollment' -Path C:\Evidence\pki\gpo-backup -
Comment 'Course 1.6'   # and any root-trust GPO from lesson 5
(Get-GPInheritance -Target 'DC=sbd,DC=test').GpoLinks | Select-Object Target, Order,
DisplayName, Enabled, Enforced | Export-Csv C:\Evidence\pki\gpo-links.csv -
NoTypeInformation
Get-ChildItem C:\Evidence\pki -Recurse -File | Get-FileHash -Algorithm SHA256 | Export-Csv
C:\Evidence\pki-manifest.csv -NoTypeInformation
Get-FileHash -Algorithm SHA256 C:\Evidence\pki-manifest.csv
```

> **WHAT SUCCESS LOOKS LIKE** Both controllers and the pilot enroll hands-free and verify with live retrieval from pki.sbd.test; after revocation and publication the test certificate is rejected for the expected reason; SBD-SUBCA01 and SBD-PKI-MGMT01 have first baselines and both controllers a rescan; and the domain controller certificate rule is answered with its evidence, its DoD companion recorded as an exception.

Your record

Evidence to keep: Finish the PKI checklist with each controller's and the pilot's certificate details, urlfetch and revocation results, renewal dates and recovery owners, the first baselines of SBD-SUBCA01 and SBD-PKI-MGMT01, the controllers' rescans, the updated checklist copies, the exception-record row, the GPO backup and link export, and C:\Evidence\pki-manifest.csv with its own hash.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	

RECORD	YOUR OBSERVATION
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What does a hands-free pilot enrollment prove?

REMEMBER Both controllers and the pilot enroll hands-free, with live revocation retrieval from pki.sbd.test. A revoked test certificate is rejected for the expected reason. Renewal, backup, and recovery each have an owner and a date; the closing scans and the closed controller finding finish the PKI chapter.

Microsoft · Publish trust data and validate clients

Microsoft · Certutil reference

Microsoft · Configure certificate autoenrollment

Microsoft · On-premises key trust deployment guide (domain controller certificates)

DISA · Security Content Automation Protocol (SCC and SCAP benchmarks)

DISA · STIGs document library (STIGs, SRGs and the CCI list)

Course review and sign-off

Before moving on, confirm each lesson left evidence behind — and that what remains open is written down, not remembered.

Lesson completion

LESSON	EVIDENCE FILED	DATE
01 Design the two-tier trust hierarchy	☐ yes	
02 Configure the offline Root CA	☐ yes	
03 Create the issuing CA request	☐ yes	
04 Sign through the offline ceremony	☐ yes	
05 Activate the issuing CA and distribute trust	☐ yes	
06 Build the pki.sbd.test publication site	☐ yes	
07 Publish the trust data at its advertised URLs	☐ yes	
08 Separate template administration	☐ yes	
09 Publish the first working templates	☐ yes	
10 Validate enrollment, revocation, and recovery	☐ yes	

Open items carried forward

Next in the learning path

That completes Configure the two-tier PKI. Course 1.7, Run DHCP on SBD-DHCP01, builds the member server that leases VLAN 80 its addresses before any fleet exists.

> **KEEP IT HONEST** Lesson completion records learning activity; it is not a system authorization decision. Your observations, not the sample values, establish what happened in your environment.

© 2026 Secure By Design Team LLC.